Université Mohamed Premier
Faculté des Sciences
Département Informatique

Année universitaire 2025-2026
Filière IA-S4 et GI-S6

Module Cyber Sécurité

Feuille de TD/TP 2

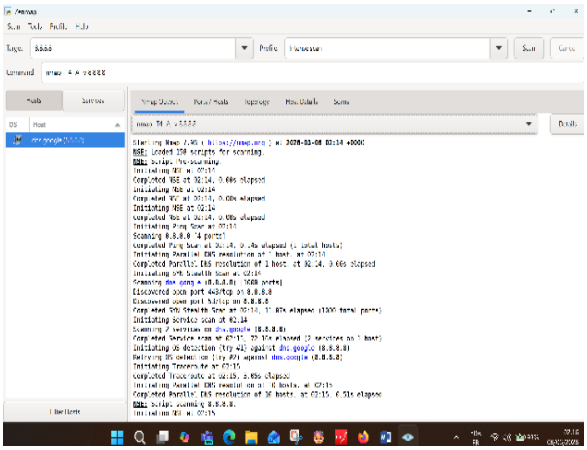
But : Maîtriser Nmap : Scanner réseau et audit de sécurité

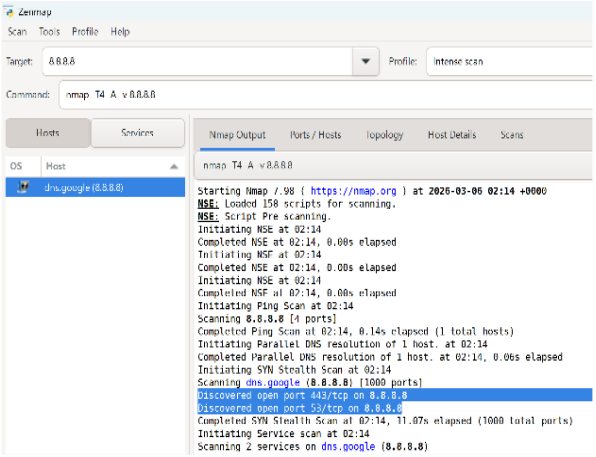
Nmap : Scanner réseau et audit de sécurité

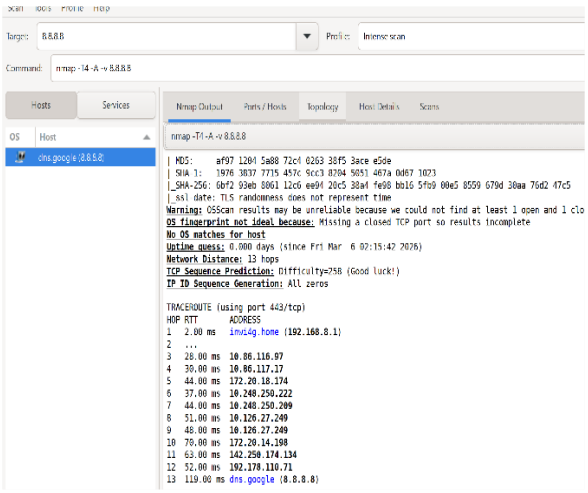
Quand on doit **découvrir les machines actives** sur un réseau, identifier les **ports ouverts** sur un serveur, ou auditer la **sécurité d'une infrastructure**, `nmap` est l'outil de référence.

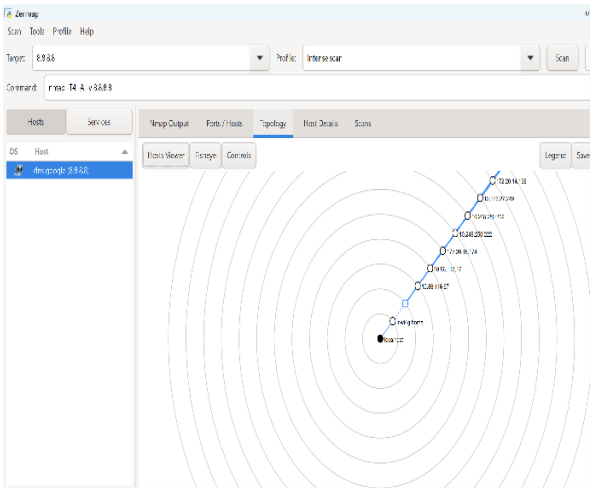
Créé en 1997 par Gordon Lyon (Fyodor), ce scanner réseau open source permet d'explorer, analyser et sécuriser des infrastructures de toute taille.

Exemple de résultat obtenu avec un scan NMAP du serveur de Google :









Installation de Nmap

- ✓ Linux Debian : `sudo apt update && sudo apt install nmap`
  `nmap --version`

- ✓ Windows : Téléchargez l'installateur depuis nmap.org/download.

L'installation inclut **Zenmap** (interface graphique) et **Npcap** (driver de capture)

- ✓ Mac OS : `brew install nmap`
  `nmap --version`

Vous allez apprendre dans ce TP :

- Découvrir les **hôtes actifs** sur un réseau
- Scanner les **ports** et identifier les **services**
- Détecter le **système d'exploitation** des cibles
- Utiliser les **scripts NSE** pour l'audit de sécurité
- **Exporter** les résultats pour documentation et comparaison

La commande Nmap dans l'écosystème sécurité

Nmap fait partie des **outils de reconnaissance réseau**. Chaque outil a sa spécialité :

Outil	Spécialité	Quand l'utiliser
`nmap`	**Découverte hôtes/ports/services**	**Cartographie réseau, audit sécurité**
`masscan`	Scan très rapide	Grands réseaux (millions d'IP)
`netcat`	Connexion manuelle	Test ponctuel d'un service
`tcpdump`	Capture de paquets	Analyse du trafic en temps réel
`wireshark`	Analyse protocolaire	Débogage réseau approfondi
`nikto`	Scan vulnérabilités web	Audit serveurs HTTP

Quand utiliser nmap vs masscan ?

Situation	nmap	masscan
Scan d'un serveur	✅ Détails complets	Overkill
Scan réseau /24	✅ Parfait	✅
Scan Internet entier	❌ Trop lent	✅ Conçu pour
Détection de services	✅ `-sV`	❌ Limité

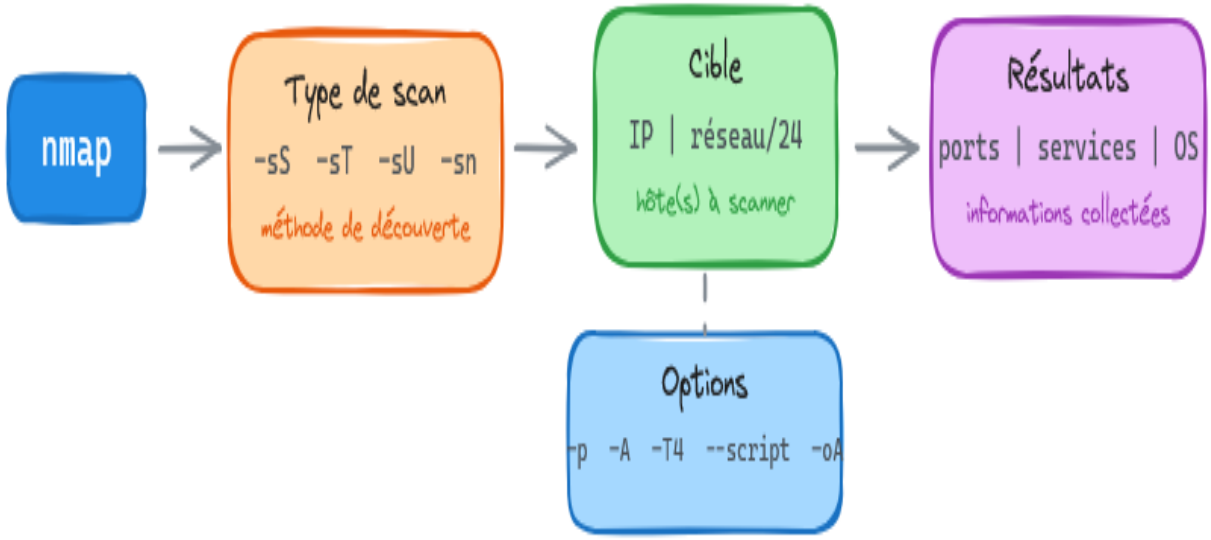
Situation	nmap	masscan
Scripts personnalisés	✅ NSE	❌
Détection d'OS	✅ -O	❌

Workflow d'audit :

nmap -sn 192.168.1.0/24
nmap -F -oA scan-initial 192.168.1.10-50
nmap -sV -sC -O -oA scan-detail 192.168.1.42
nmap --script vuln -p 80,443 192.168.1.42

Comprendre la commande nmap. Comment fonctionne nmap ?

nmap = Définir la cible → Choisir le type de scan → Analyser les résultats



Points clés

- nmap envoie des paquets réseau pour découvrir hôtes, ports et services
- Le scan SYN (-sS) est le plus courant : rapide et discret
- Le scan TCP Connect (-sT) complète la connexion : plus visible mais fiable
- Le scan UDP (-sU) est lent mais détecte DNS, DHCP, SNMP
- L'option -A combine : détection OS, services, scripts et traceroute
- -T0 à -T5 contrôle la vitesse (T4 = bon compromis rapidité/discrétion)

Règles d'or

1 :**Toujours avoir une autorisation avant de scanner** Scanner sans autorisation est illégal et peut être considéré comme une attaque

2 : **Commencer par un scan léger puis approfondir** Un scan -A ou -p- sur un grand réseau peut prendre des heures et déclencher des alertes

3 : **Exporter les résultats pour comparaison** -oA génère tous les formats : permet de comparer l'état du réseau dans le temps

Vocabulaire essentiel de Nmap

-sS :Scan SYN (semi-ouvert, rapide)

-sT: Scan TCP Connect (complet)

-sU : Scan UDP

-p 22,80,443 : Ports spécifiques

-p- : Tous les 65535 ports

-A : Scan agressif (OS + services + scripts)

6 options avancées

-sV :Détection des versions de services
-O :Détection du système d'exploitation
-sn :Ping scan (découverte hôtes sans scan ports)
--script :Exécuter des scripts NSE
-T4 : Timing agressif (rapide)
-oA :Exporter dans tous les formats
`nmap` envoie des **paquets réseau** vers les cibles, analyse les **réponses** (ou leur absence), et en déduit l'état des ports et les services qui tournent.

Syntaxe minimale

```
nmap [OPTIONS] [CIBLE]
```

Les types de scans principaux

Scan	Option	Usage	Vitesse
SYN	`-sS`	Scan standard (semi-ouvert)	Rapide
TCP Connect	`-sT`	Connexion complète	Moyen
UDP	`-sU`	Services UDP (DNS, DHCP)	Lent
Ping	`-sn`	Découverte hôtes uniquement	Très rapide

Scan SYN vs TCP Connect

Le **scan SYN** (`-sS`) est le plus utilisé :

```
# Scan SYN (nécessite root) - rapide et discret
sudo nmap -sS 192.168.1.100

# Scan TCP Connect - pas besoin de root, mais plus lent
nmap -sT 192.168.1.100
```

Différence technique :

- **SYN** : envoie SYN, reçoit SYN-ACK, envoie RST (pas de connexion complète)
- **TCP Connect** : établit une vraie connexion TCP (3-way handshake complet)

Spécifier les ports

Syntaxe	Signification	Exemple
`-p N`	Port N seul	`-p 22` → port SSH
`-p N,M,P`	Ports N, M et P	`-p 22,80,443`
`-p N-M`	De N à M	`-p 1-1024` → ports privilégiés
`-p-`	Tous les 65535 ports	Exhaustif mais lent
`-F`	Fast (100 ports courants)	Rapide

Détection avancée

nmap -sV 192.168.1.100

sudo nmap -O 192.168.1.100

sudo nmap -A 192.168.1.100

Contrôle de la vitesse

L'option `-T` contrôle l'agressivité du scan :

Niveau	Nom	Usage
`-T0`	Paranoid	Évitement IDS extrême
`-T1`	Sneaky	Évitement IDS
`-T2`	Polite	Charge réseau réduite
`-T3`	Normal	Par défaut
`-T4`	Aggressive	Réseaux rapides et fiables
`-T5`	Insane	Très rapide, risque de rater des ports

Recommandation : `-T4` pour les audits internes, `-T2` ou `-T3` pour rester discret.

Les Modèles de scans courants Qlqs exemples

Ces recettes couvrent les cas d'usage les plus fréquents. Cliquez sur un pattern pour voir la formule complète et un exemple prêt à copier.

- ✓ Scan basique Base :

Découvrir les ports ouverts sur une cible `nmap 192.168.1.100`

- ✓ Ports spécifiques Base :

Scanner uniquement certains ports `nmap -p 22,80,443,8080 192.168.1.100`

- ✓ Tous les ports Inter.

Scanner les 65535 ports :`nmap -p- -T4 192.168.1.100`

- ✓ Détection de services Base

Identifier les versions des services :nmap -sV -p 22,80 192.168.1.100

- ✓ Détection d'OS Inter.

Identifier le système d'exploitation :`sudo nmap -O 192.168.1.100`

- ✓ Scan de vulnérabilités Avancé

Détecter les vulnérabilités connues :`nmap --script vuln -p 22,80,443 192.168.1.100`

Export des résultats

nmap -oN scan.txt 192.168.1.100

nmap -oX scan.xml 192.168.1.100

nmap -oG scan.gnmap 192.168.1.100

nmap -oA scan-2026-01-28 192.168.1.100

Syntaxe résumé:

`nmap <cible>` Scan basique des 1000 ports courants

`nmap <réseau>/24` Scanner tout un sous-réseau

`nmap -iL fichier.txt` Lire les cibles depuis un fichier

Commandes types :

Scan basique Découvrir les ports ouverts sur une cible

```
nmap 192.168.1.100
```

Ports spécifiques Scanner uniquement certains ports

```
nmap -p 22,80,443,8080 192.168.1.100
```

Détection de services Identifier les versions des services

```
nmap -sV -p 22,80 192.168.1.100
```

Découverte réseau Trouver les hôtes actifs sans scanner les ports

```
nmap -sn 192.168.1.0/24
```

Export multi-format Sauvegarder les résultats pour analyse

```
nmap -oA scan-2025-01-28 192.168.1.100
```

Options

-p <ports>	Ports spécifiques	-p 22,80,443
-p <debut>-<fin>	Plage de ports	-p 1-1024
-p-	Tous les 65535 ports	nmap -p- localhost
-F	Fast scan (100 ports)	nmap -F localhost
-sS	Scan SYN (semi-ouvert, rapide)	sudo nmap -sS localhost
-sT	Scan TCP Connect (complet)	nmap -sT localhost
-sU	Scan UDP	sudo nmap -sU -p 53 localhost
-sn	Ping scan (découverte hôtes)	nmap -sn 192.168.1.0/24
-sV	Détection des versions de services	nmap -sV localhost
-O	Détection du système d'exploitation	sudo nmap -O localhost
-A	Scan agressif (OS + services + scripts)	sudo nmap -A localhost
--script <nom>	Exécuter un script NSE	--script http-title
--script <catégorie>	Scripts d'une catégorie	--script vuln
--script-help	Aide sur les scripts	nmap --script-help "*ssh*"
-T<0-5>	Niveau de timing	-T4 (agressif)
-n	Pas de résolution DNS	nmap -n 192.168.1.0/24
--min-rate	Paquets/seconde minimum	--min-rate 1000
-oN <fichier>	Export format normal	-oN scan.txt
-oX <fichier>	Export format XML	-oX scan.xml
-oG <fichier>	Export format grepable	-oG scan.gnmap
-oA <prefix>	Export tous formats	-oA scan-2025
-v / -vv	Mode verbeux	nmap -vv localhost
-Pn	Ignorer le ping (hôte down)	nmap -Pn localhost
--reason	Afficher la raison du résultat	nmap --reason localhost

Les scripts NSE (Nmap Scripting Engine) sur https://nmap.org/book/nse.html

Le **NSE** permet d'automatiser des tâches avancées grâce à des scripts en Lua.
Introduction

Le moteur de script Nmap (NSE) est l'une des fonctionnalités les plus puissantes et les plus flexibles de Nmap. Il permet aux utilisateurs d'écrire (et de partager) des scripts simples pour automatiser une grande variété de tâches réseau. Ces scripts sont ensuite exécutés en parallèle avec la vitesse et l'efficacité que vous attendez de Nmap. Les utilisateurs peuvent s'appuyer sur l'ensemble croissant et diversifié de scripts distribués avec Nmap, ou écrire les leurs pour répondre à des besoins personnalisés.
NSE conçu pour qu'il soit polyvalent, avec les tâches suivantes :

- ✓ Découverte du réseau
- ✓ *Service and Application Version Detection*)
- ✓ Vulnerability detection
- ✓ Backdoor detection
- ✓ Vulnerability exploitation
- ✓ Etc..

Les scripts sont écrits dans le langage de programmation **Lua** intégré, version 5.4. Le langage lui-même est bien documenté dans les livres Programming in Lua, Fourth Edition et Lua 5.2 Reference Manual. Le manuel de référence, mis à jour pour Lua 5.4, est également disponible gratuitement en ligne.
NSE est activé avec l'option -sC (ou --script si vous souhaitez spécifier un ensemble personnalisé de scripts) et les résultats sont intégrés dans la sortie normale et XML de Nmap.

Une analyse de script typique est présentée dans l'exemple dans la figure 1. Les scripts de service produisant une sortie dans cet exemple sont ssh-hostkey, qui fournit les clés SSH RSA et DSA du système, et rpcinfo, qui interroge portmapper pour énumérer les services disponibles. Le seul script hôte produisant une sortie dans cet exemple est smb-os-discovery, qui collecte diverses informations auprès des serveurs SMB. Nmap a découvert toutes ces informations en un tiers de seconde.
Exemple figure.1. Sortie NSE typique

```
# nmap -sC -p22,111,139 -T4 localhost

Starting Nmap ( https://nmap.org )
Nmap scan report for flog (127.0.0.1)
PORT     STATE SERVICE
22/tcp   open  ssh
| ssh-hostkey: 1024 b1:36:0d:3f:50:dc:13:96:b2:6e:34:39:0d:9b:1a:38 (DSA)
|_2048 77:d0:20:1c:44:1f:87:a0:30:aa:85:cf:e8:ca:4c:11 (RSA)
111/tcp  open  rpcbind
| rpcinfo:
| 100000  2,3,4    111/udp  rpcbind
| 100024  1      56454/udp  status
|_100000  2,3,4    111/tcp  rpcbind
139/tcp  open  netbios-ssn

Host script results:
| smb-os-discovery: Unix
| LAN Manager: Samba 3.0.31-0.fc8
|_Name: WORKGROUP

Nmap done: 1 IP address (1 host up) scanned in 0.33 seconds
```

Note importante : Les scripts ne s'exécutent pas dans un bac à sable (sandbox). Un script malveillant ou mal conçu peut endommager votre système ou compromettre votre vie privée.

Les 4 Phases d'Exécution (Types de Scripts)

Le moment où un script s'exécute dépend de sa fonction et des données dont il a besoin :

1. **Prerule scripts** : S'exécutent avant tout scan. Utiles pour générer de nouvelles cibles (ex: requêtes DHCP/DNS).

2. **Host scripts** : S'exécutent durant la phase normale de scan, après la découverte de l'hôte et du système d'exploitation.
3. **Service scripts** : Les plus communs. Ils s'exécutent contre des services spécifiques (ex: un script de vulnérabilité HTTP ne tournera que si le port 80/443 est ouvert).
4. **Postrule scripts** : S'exécutent après le scan de toutes les cibles. Idéal pour agréger des données ou formater un rapport final.

Catégories de scripts Classification par Catégories

Les scripts sont organisés par catégories pour faciliter leur sélection :

Catégorie	Description	Risque
Safe	Conçus pour ne pas faire planter les services ni consommer trop de bande passante.	Faible
Default (-sC)	Scripts rapides, utiles et fiables. Le standard pour un premier scan.	Faible
Discovery	Tente d'extraire plus d'infos (SNMP, partages SMB, titres de pages Web).	Moyen
Auth / Brute	Teste les identifiants par défaut ou via attaque par force brute.	Moyen
Vuln	Recherche des vulnérabilités spécifiques connues.	Moyen
Intrusive	Risque élevé de crash du système cible ou d'être détecté par un IDS/IPS.	Élevé
Exploit / DoS	Tente activement d'exploiter une faille ou de saturer un service.	Très Élevé

Syntaxe et Utilisation en Ligne de Commande

1. Sélection de scripts

- **Par défaut :** nmap -sC <cible>
- **Par catégorie :** nmap --script "discovery,safe" <cible>
- **Par exclusion :** nmap --script "not intrusive" <cible>
- **Par wildcard (masque) :** nmap --script "http-*" <cible> (lance tous les scripts commençant par http).

2. Gestion des arguments

Certains scripts nécessitent des paramètres (ex: un chemin d'accès ou un identifiant) : nmap --script http-auth --script-args user=admin,pass=1234 <cible>

3. Aide et Documentation

Pour comprendre ce que fait un script avant de le lancer : nmap --script-help <nom_du_script>

Options de Debugging et Mise à jour

- **--script-trace** : Affiche toutes les données envoyées et reçues par les scripts (niveau application).
- **--script-updatedb** : Indispensable après avoir ajouté un nouveau script manuellement dans le répertoire de Nmap pour qu'il soit reconnu.

Utilisation des scripts

nmap -sC 192.168.1.100

nmap --script discovery 192.168.1.100

nmap --script http-title -p 80 192.168.1.100

nmap --script "http-*" -p 80,443 192.168.1.100

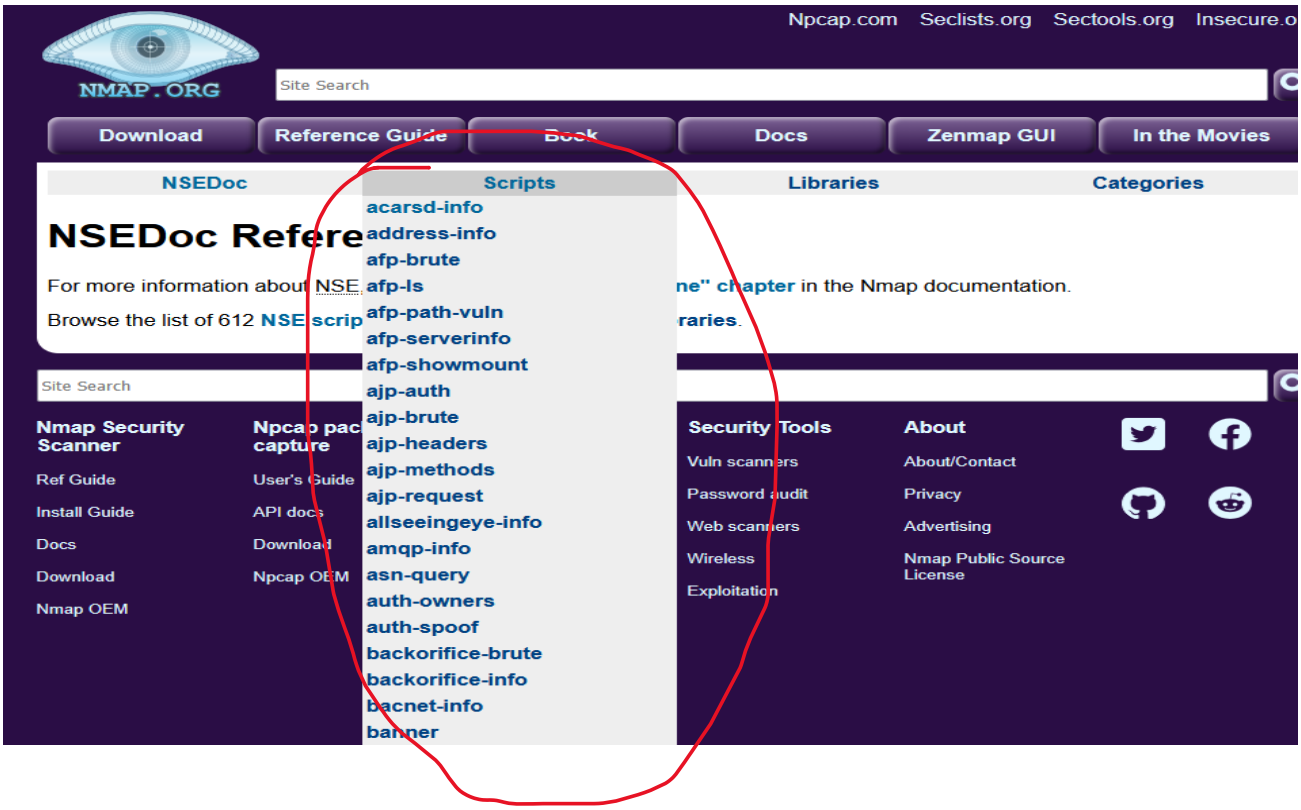
nmap --script http-brute --script-args userdb=users.txt -p 80 192.168.1.100

Scripts utiles pour l'audit

Fenêtre de terminal

```
# Recherche de vulnérabilités
nmap --script vuln -p 80,443 192.168.1.100
# Énumération HTTP
nmap --script http-enum -p 80,443 192.168.1.100
# Détection SSL/TLS
nmap --script ssl-enum-ciphers -p 443 192.168.1.100

# Informations SSH
nmap --script ssh-auth-methods -p 22 192.168.1.100

# Découvrir les scripts disponibles
nmap --script-help "*ssh*"
```

Pour plus sur les scripts consulter : https://nmap.org/nsedoc/index.html